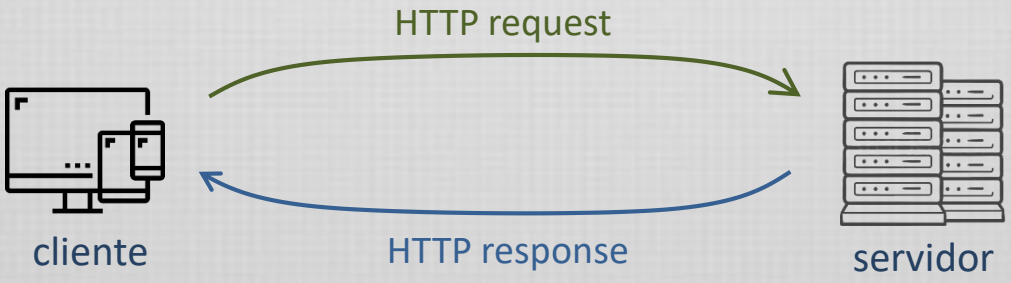
Ingeniería de Aplicaciones Web

Diego C. Martínez

Departamento de Ciencias e Ingeniería de la Computación
Universidad Nacional del Sur

Stateless

HTTP es un protocolo *stateless*,
cada petición es una transacción independiente de las peticiones anteriores
El protocolo no contempla tener "memoria del pasado"

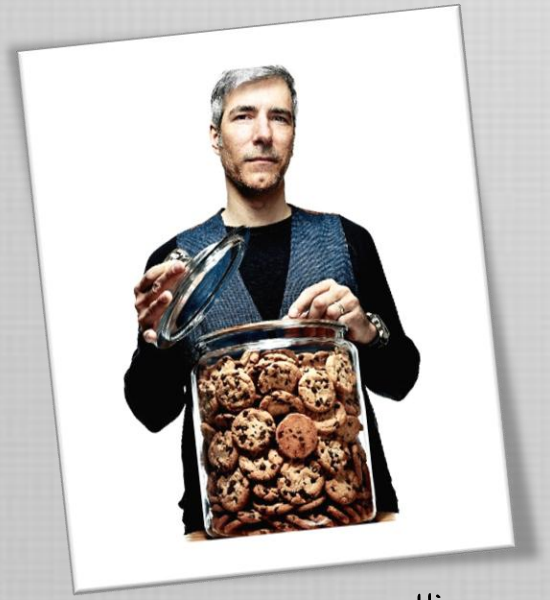


¿Cómo es posible entonces el login?
El servidor nos pregunta la identidad y luego "nos recuerda"

¿Cómo distingue el servidor a cada usuario y "lo recuerda"?

Stateless

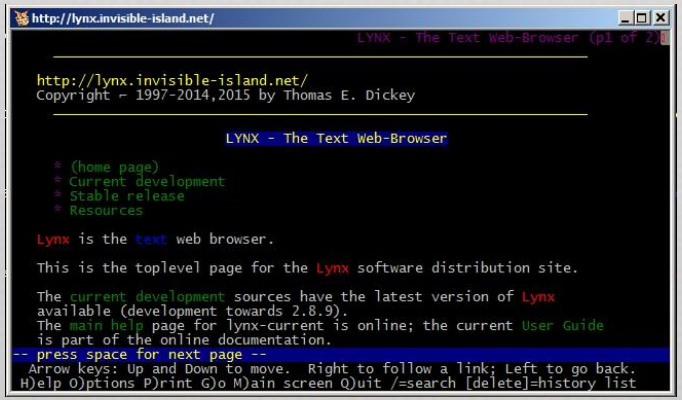
HTTP es un protocolo *stateless*,
cada petición es una transacción independiente de las peticiones anteriores
El protocolo no contempla tener "memoria del pasado"



Louis Montulli

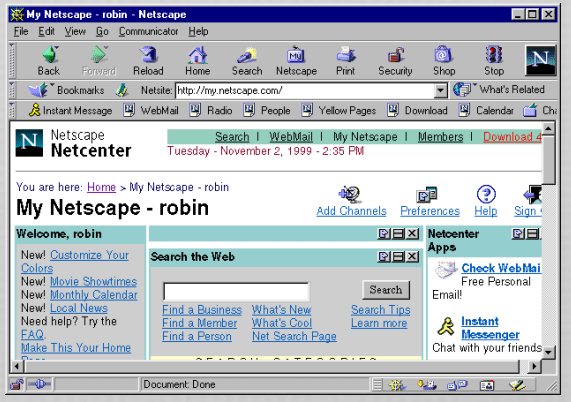
Lynx

1992



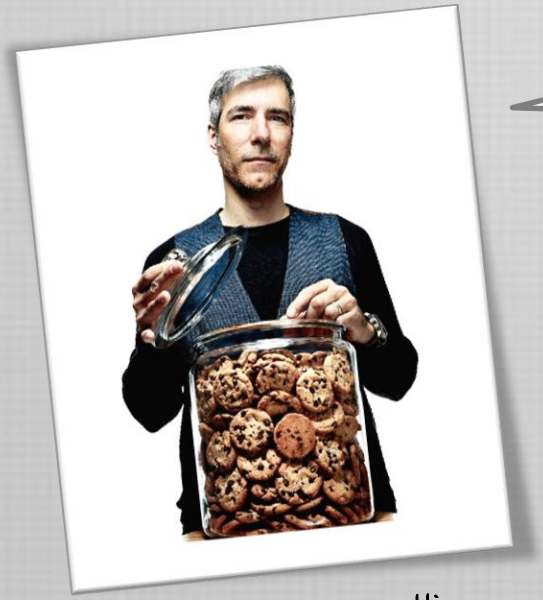
Netscape

1994



Stateless

HTTP es un protocolo *stateless*,
cada petición es una transacción independiente de las peticiones anteriores
El protocolo no contempla tener "memoria del pasado"



Louis Montulli

Que el servidor envíe un identificador al cliente
Y que el cliente lo reenvíe automáticamente en futuros requests

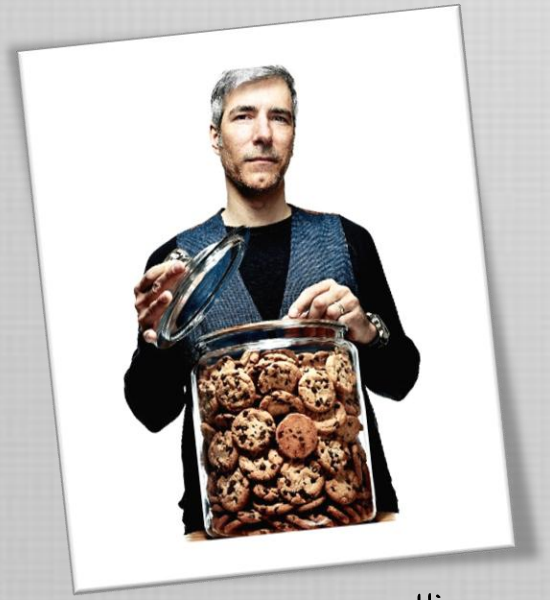
Dos headers son introducidos

`Set-Cookie`	(del Servidor al Cliente)
`Cookie`	(del Cliente al Servidor)

Fueron motivo de algunas preocupaciones desde el comienzo
"El servidor puede reconocerme sin que yo lo sepa"
"Hay información de terceros que queda en mi navegador"

Stateless

HTTP es un protocolo *stateless*,
cada petición es una transacción independiente de las peticiones anteriores
El protocolo no contempla tener "memoria del pasado"



Louis Montulli

Las cookies son aún una parte importante en la sesión del cliente

La actividad (requests) reiterada y continua del cliente con el servidor, que permite mantener estado entre ellos

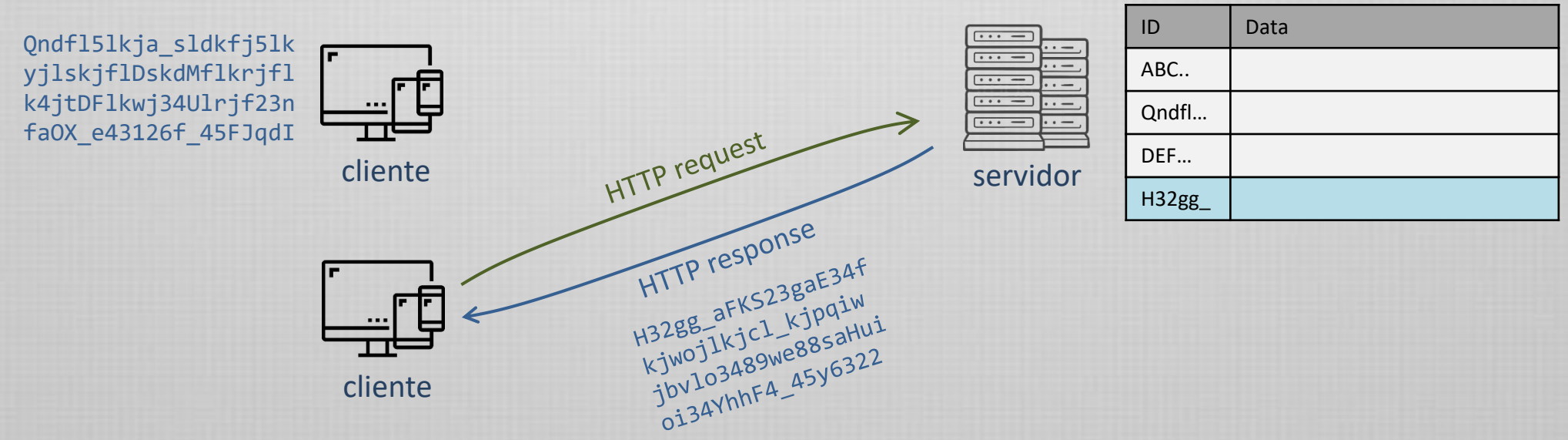
Stateless

HTTP request
cliente
servidor
HTTP response
+ identificador
Qndfl5lkja_sldkfj5lk
yjlskjflDskdMflkrjfl
k4jtDFlkwj34Ulrjf23n
faOX_e43126f_45FJqdI
cookies

Stateless

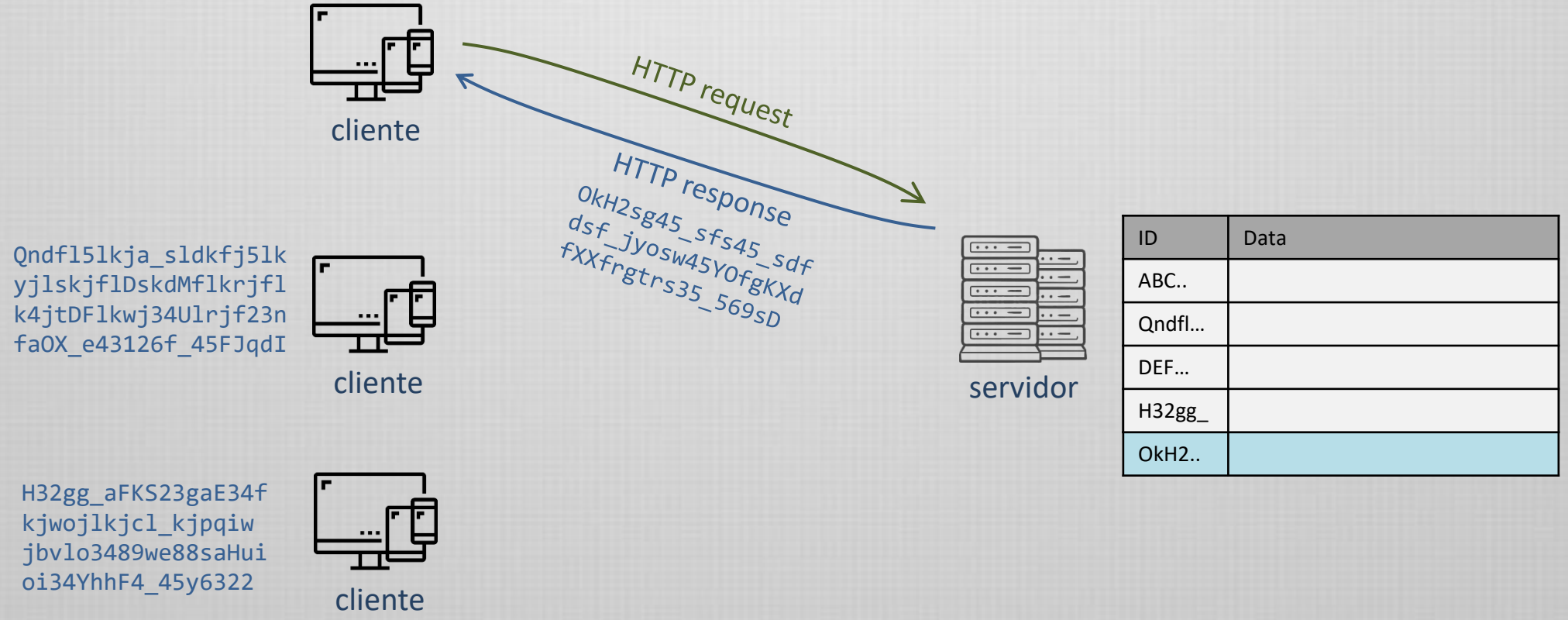
Qndfl5lkja_sldkfj5lk
yjlskjflDskdMflkrjfl
k4jtDFlkwj34Ulrjf23n
faOX_e43126f_45FJqdI
HTTP request
Qndfl5lkja_sldkfj5lk
yjlskjflDskdMflkrjfl
k4jtDFlkwj34Ulrjf23n
faOX_e43126f_45FJqdI
cliente
servidor
ID
Data
ABC..
Qndfl...
DEF...

Stateless



ID	Data
ABC..	
Qndfl...	
DEF...	
H32gg_	

Stateless


cliente
HTTP request
HTTP response
OkH2sg45_sfs45_sdf
dsf_jyosw45YOfgKXd
fXXfrgtrs35_569sD
Qndfl5lkja_sldkfj5lk
yjlskjflDskdMflkrjfl
k4jtDFlkwj34Ulrjf23n
faOX_e43126f_45FJqdI
cliente
H32gg_aFKS23gaE34f
kjwojlkjcl_kjpqiw
jbvlo3489we88saHui
oi34YhhF4_45y6322
cliente
servidor
ID
Data
ABC..
Qndfl...
DEF...
H32gg_
OkH2..

Stateless

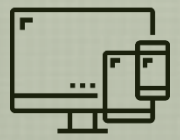
OkH2sg45_sfs45_sdf
dsf_jyosw45YOfgKXd
fXXfrgtrs35_569sD

cliente

Qndfl5lkja_sldkfj5lk
yjlskjflDskdMflkrjfl
k4jtDFlkwj34Ulrjf23n
faOX_e43126f_45FJqdI

cliente

H32gg_aFKS23gaE34f
kjwojlkjcl_kjpqiw
jbvlo3489we88saHui
oi34YhhF4_45y6322



cliente

Esto NO es HTTP
Es un mecanismo del servidor

servidor

ID	Data
ABC..	
Qndfl...	
DEF...	
H32gg_	
OkH2..	

Cookies

Las *cookies* son información agregada al cliente para poder identificar diversas características

Identidad (tokens)
Personalizaciones
Seguridad
Gestión de publicidad
Autocompletado de formularios

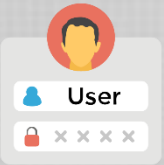
Existen regulaciones sobre el uso de las cookies en las aplicaciones web

"… their use should be allowed on condition that users are provided with clear and precise information in accordance with Directive 95/46/EC about the purposes of cookies or similar devices so as to ensure that users are made aware of information being placed on the terminal equipment they are using. Users should have the opportunity to refuse to have a cookie or similar device stored on their terminal equipment".

Identidad y permisos

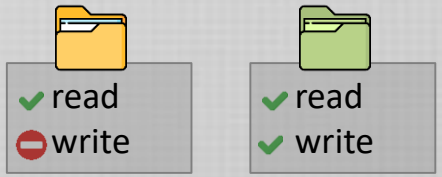
Autenticación

Prueba de identidad
Significa verificar que el usuario es quien dice ser



Autorización

Control de las acciones del usuario en función de su identidad y nivel de acceso



ACL = Access Control List

Otra forma

¿Y si el servidor no guardara sesión y el cliente trajera todo lo necesario en cada request?

Antes (sesión clásica)

1. Login
2. Servidor crea `sessionId`
3. Guarda el estado del usuario
4. Le da a al cliente la `sessionId`
5. El cliente se identifica constantemente enviando `sessionId`
6. Servidor consulta sus registros y reacciona al pedido acordemente

Ahora (el servidor no guarda nada)

1. Login
2. Servidor genera un dato con información sobre el cliente (nombre, roles, lo que sea necesario)
3. Le da ese dato al cliente
4. El cliente repite ese dato en cada request
5. El servidor recibe ese dato y ve información del cliente

El dato con información sobre el cliente requiere seguridad

Otra forma

¿Y si el servidor no guardara sesión y el cliente trajera todo lo necesario en cada request?

Antes (sesión clásica)

1. Login
2. Servidor crea `sessionId`
3. Guarda el estado del usuario
4. Le da a al cliente la `sessionId`
5. El cliente se identifica constantemente enviando `sessionId`
6. Servidor consulta sus registros y reacciona al pedido acordemente

Ahora (el servidor no guarda nada)

1. Login
2. Servidor genera un dato con información sobre el cliente (nombre, roles, lo que sea necesario)

```
{   "sub": "user123",
  "role": "admin",
  "exp": 1710000000
}
```

3. El servidor firma digitalmente el dato
4. Le da ese dato al cliente
5. El cliente repite ese dato en cada request
6. El servidor recibe ese dato y
   - verifica la firma
   - ve información del cliente

Otra forma

JSON Web Token

Estándar abierto (RFC 7519) que define una forma
compacta y autónoma
de transmitir información de manera segura
entre dos partes como un objeto JSON.

eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIxMjM0NTY3ODkwIiwibmFtZSI6IkpvaG4gRG9lIiwiYWRtaW4iOnRydWUsImlhdCI6MTUxNjIzOTAyMn0.KMUFsIDTnFmyG3nMiGM6H9FNFUROf3wh7SmqJp-QV30

Otra forma

eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIxMjM0NTY3ODkwIiwibmFtZSI6IkpvaG4gRG9lIiwiYWRtaW4iOnRydWUsImlhdCI6MTUxNjIzOTAyMn0.KMUFsIDTnFmyG3nMiGM6H9FNFUROf3wh7SmqJp-QV30

Otra forma

eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIxMjM0NTY3ODkwIiwibmFtZSI6IkpvaG4gRG9lIiwiYWRtaW4iOnRydWUsImlhdCI6MTUxNjIzOTAyMn0.KMUFsIDTnFmyG3nMiGM6H9FNFUROf3wh7SmqJp-QV30

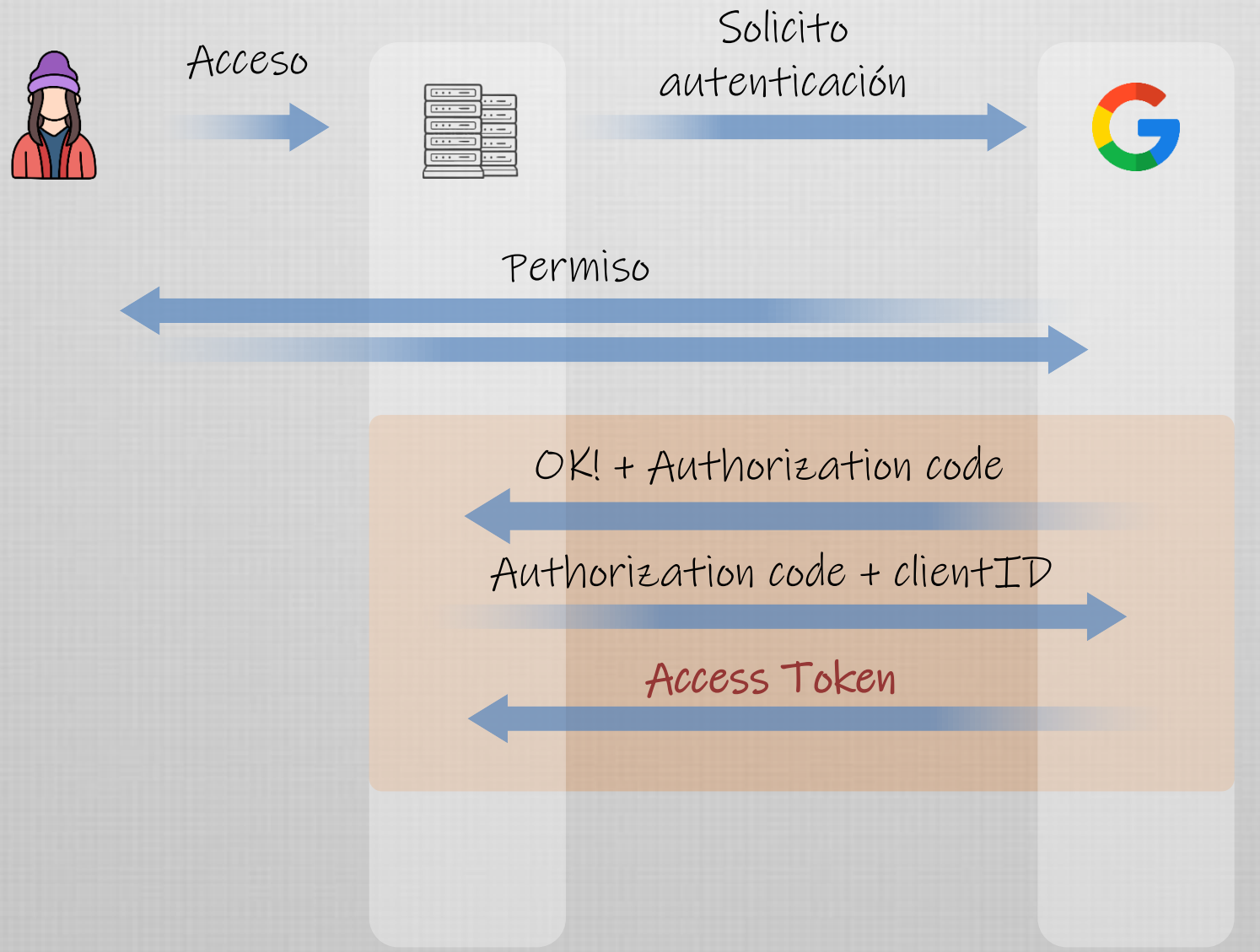

```
{
  "alg": "HS256",
  "typ": "JWT"
}
```

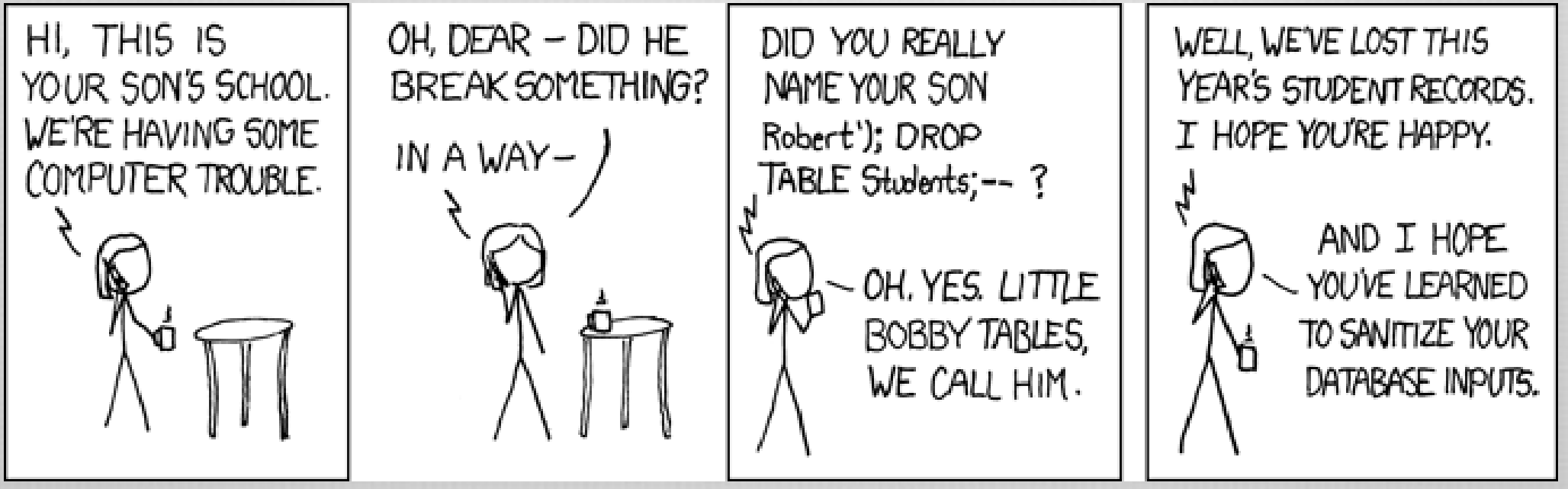
```
{
  "sub": "1234567890",
  "name": "John Doe",
  "admin": true,
  "iat": 1516239022
}
```


Firma basada en un secreto

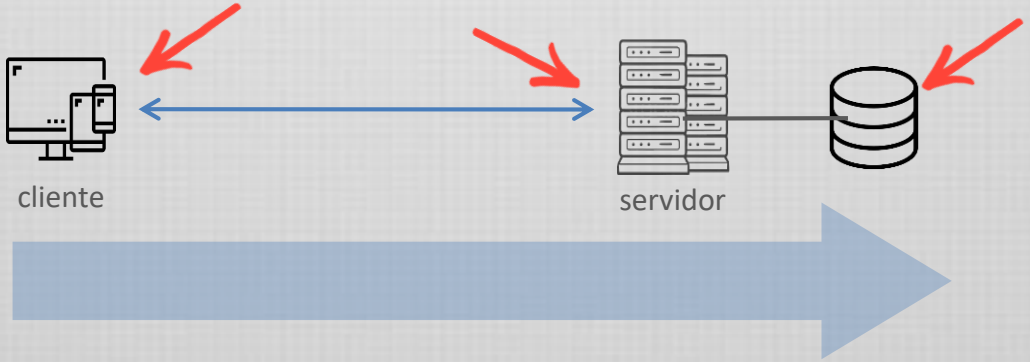
a-string-secret-at-least-256-bits-long

OAuth


Acceso
Solicito autenticación
Permiso
OK! + Authorization code
Authorization code + clientID
Access Token


HI, THIS IS YOUR SON'S SCHOOL. WE'RE HAVING SOME COMPUTER TROUBLE.
OH, DEAR – DID HE BREAK SOMETHING?
IN A WAY–
DID YOU REALLY NAME YOUR SON Robert'); DROP TABLE Students;-- ?
OH. YES. LITTLE BOBBY TABLES, WE CALL HIM.
WELL, WE'VE LOST THIS YEAR'S STUDENT RECORDS. I HOPE YOU'RE HAPPY.
AND I HOPE YOU'VE LEARNED TO SANITIZE YOUR DATABASE INPUTS.

Seguridad



The Ten Most Critical Web Application Security Risks

Ranking con una revisión aproximadamente cada tres a cuatro años

2021	2025
A01:2021-Broken Access Control	A01:2025-Broken Access Control
A02:2021-Cryptographic Failures	A02:2025-Security Misconfiguration
A03:2021-Injection	(New) A03:2025-Software Supply Chain Failures*
A04:2021-Insecure Design	A04:2025-Cryptographic Failures
A05:2021-Security Misconfiguration	A05:2025-Injection
A06:2021-Vulnerable and Outdated Components	A06:2025-Insecure Design
A07:2021-Identification and Authentication Failures	A07:2025-Authentication Failures
A08:2021-Software and Data Integrity Failures	A08:2025-Software or Data Integrity Failures
A09:2021-Security Logging and Monitoring Failures*	A09:2025-Security Logging & Alerting Failures*
A10:2021-Server-Side Request Forgery (SSRF)*	(New) A10:2025-Mishandling of Exceptional Conditions

* From the Survey

* From the Survey

OWASP – Top 10

A01:2025-Broken Access Control
A02:2025-Security Misconfiguration
A03:2025-Software Supply Chain Failures*
A04:2025-Cryptographic Failures
A05:2025-Injection
A06:2025-Insecure Design
A07:2025-Authentication Failures
A08:2025-Software or Data Integrity Failures
A09:2025-Security Logging & Alerting Failures*
A10:2025-Mishandling of Exceptional Conditions

OWASP – Top 10

A01:2025-Broken Access Control
A02:2025-Security Misconfiguration
A03:2025-Software Supply Chain Failures*
A04:2025-Cryptographic Failures
A05:2025-Injection
A06:2025-Insecure Design
A07:2025-Authentication Failures
A08:2025-Software or Data Integrity Failures
A09:2025-Security Logging & Alerting Failures*
A10:2025-Mishandling of Exceptional Conditions

A01:2025-Broken Access Control
A02:2025-Security Misconfiguration
A03:2025-Software Supply Chain Failures*
A04:2025-Cryptographic Failures
A05:2025-Injection
A06:2025-Insecure Design
A07:2025-Authentication Failures
A08:2025-Software or Data Integrity Failures
A09:2025-Security Logging & Alerting Failures*
A10:2025-Mishandling of Exceptional Conditions

Control de Acceso deficiente

Common Weakness Enumerations

CWE-200: Exposición de información sensible a un actor no autorizado,

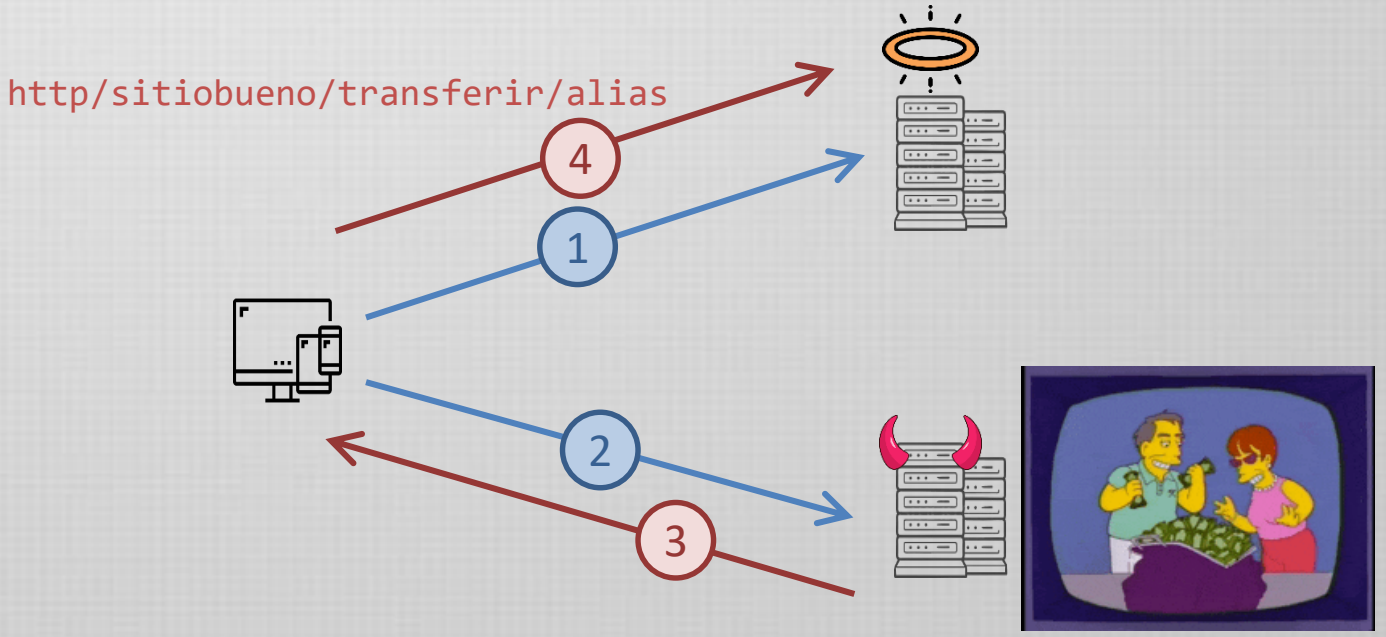
CWE-201: Exposición de información confidencial a través de datos enviados, y

CWE-352: Falsificación de Peticiones en Sitos Cruzados (CSRF)

OWASP – Top 10

A01:2025-Broken Access Control
A02:2025-Security Misconfiguration
A03:2025-Software Supply Chain Failures*
A04:2025-Cryptographic Failures
A05:2025-Injection
A06:2025-Insecure Design
A07:2025-Authentication Failures
A08:2025-Software or Data Integrity Failures
A09:2025-Security Logging & Alerting Failures*
A10:2025-Mishandling of Exceptional Conditions

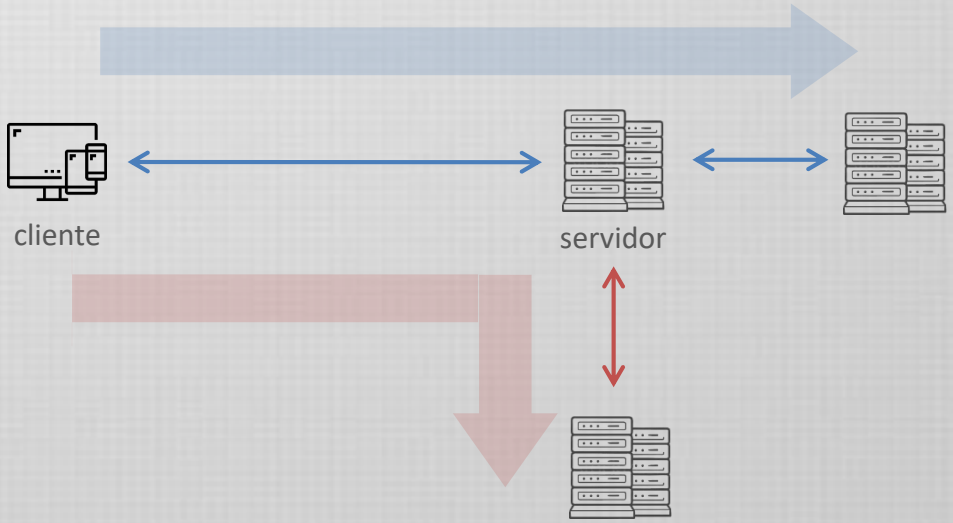
CSRF = Cross Site Request Forgery




```
<img src="http/sitiobueno/transferir/alias">
```

A01:2025-Broken Access Control
A02:2025-Security Misconfiguration
A03:2025-Software Supply Chain Failures*
A04:2025-Cryptographic Failures
A05:2025-Injection
A06:2025-Insecure Design
A07:2025-Authentication Failures
A08:2025-Software or Data Integrity Failures
A09:2025-Security Logging & Alerting Failures*
A10:2025-Mishandling of Exceptional Conditions

Falsificación de solicitud del servidor



A01:2025-Broken Access Control
A02:2025-Security Misconfiguration
A03:2025-Software Supply Chain Failures*
A04:2025-Cryptographic Failures
A05:2025-Injection
A06:2025-Insecure Design
A07:2025-Authentication Failures
A08:2025-Software or Data Integrity Failures
A09:2025-Security Logging & Alerting Failures*
A10:2025-Mishandling of Exceptional Conditions

Falsificación de solicitud del servidor

```
POST /product/stock HTTP/1.0
Content-Type: application/x-www-form-urlencoded
Content-Length: ..

stockApi=http://stock.sitio.com/product/stock/?id=12
```

```
POST /product/stock HTTP/1.0
Content-Type: application/x-www-form-urlencoded
Content-Length: ..

stockApi=http://localhost/admin
```

A01:2025-Broken Access Control
A02:2025-Security Misconfiguration
A03:2025-Software Supply Chain Failures*
A04:2025-Cryptographic Failures
A05:2025-Injection
A06:2025-Insecure Design
A07:2025-Authentication Failures
A08:2025-Software or Data Integrity Failures
A09:2025-Security Logging & Alerting Failures*
A10:2025-Mishandling of Exceptional Conditions

Configuración incorrecta de las aplicaciones o servidores

CWE-260 Password in Configuration File
CWE-315 Cleartext Storage of Sensitive Information in a Cookie
CWE-526 Exposure of Sensitive Information Through Environmental Variables
CWE-537 Java Runtime Error Message Containing Sensitive Information
CWE-541 Inclusion of Sensitive Information in an Include File
CWE-547 Use of Hard-coded, Security-relevant Constants
CWE-756 Missing Custom Error Page
…

A01
A02
A03
A04
A05
A06
A07
A08
A09
A10

HTTP Status 500 -

type Exception report

message

description The server encountered an internal error that prevented it from fulfilling this request.

exception

```
java.lang.NullPointerException
        com.examresults.Database.checkLogin(Database.java:82)
        com.examresults.Login.doPost(Login.java:59)
        javax.servlet.http.HttpServlet.service(HttpServlet.java:650)
        javax.servlet.http.HttpServlet.service(HttpServlet.java:731)
        org.apache.tomcat.websocket.server.WsFilter.doFilter(WsFilter.java:52)
```

note The full stack trace of the root cause is available in the Apache Tomcat/7.0.68 (Ubuntu) logs.

Apache Tomcat/7.0.68 (Ubuntu)

A01:2025-Broken Access Control
A02:2025-Security Misconfiguration
A03:2025-Software Supply Chain Failures*
A04:2025-Cryptographic Failures
A05:2025-Injection
A06:2025-Insecure Design
A07:2025-Authentication Failures
A08:2025-Software or Data Integrity Failures
A09:2025-Security Logging & Alerting Failures*
A10:2025-Mishandling of Exceptional Conditions

Fallas en la cadena de suministro de software

Componentes desactualizados y/o vulnerables

En general cualquier vulnerabilidad en third-party software

CWE-937 OWASP Top 10 2013: Using Components with Known Vulnerabilities

CWE-1104 Use of Unmaintained Third Party Components

A01:2025-Broken Access Control
A02:2025-Security Misconfiguration
A03:2025-Software Supply Chain Failures*
A04:2025-Cryptographic Failures
A05:2025-Injection
A06:2025-Insecure Design
A07:2025-Authentication Failures
A08:2025-Software or Data Integrity Failures
A09:2025-Security Logging & Alerting Failures*
A10:2025-Mishandling of Exceptional Conditions

Protección defectuosa de datos en *tránsito* y en *reposo*

CWE-261 Weak Encoding for Password
CWE-310 Cryptographic Issues
CWE-319 Cleartext Transmission of Sensitive Information
CWE-322 Key Exchange without Entity Authentication
CWE-324 Use of a Key Past its Expiration Date
CWE-326 Inadequate Encryption Strength
CWE-818 Insufficient Transport Layer Protection

A01:2025-Broken Access Control
A02:2025-Security Misconfiguration
A03:2025-Software Supply Chain Failures*
A04:2025-Cryptographic Failures
A05:2025-Injection
A06:2025-Insecure Design
A07:2025-Authentication Failures
A08:2025-Software or Data Integrity Failures
A09:2025-Security Logging & Alerting Failures*
A10:2025-Mishandling of Exceptional Conditions

Contaminación intrusiva de datos

Entradas de usuario no confiable son enviadas a un intérprete y causa que éste intérprete ejecute estas entradas como comandos

```
$username = $_POST['username'];
$pass     = $_POST['pass'];
$email    = $_POST['email'];

$sql = "INSERT INTO users (user,pass,mail)
        VALUES ('$username','$pass','$email')";
```

```
INSERT INTO users (user,pass,mail)
VALUES ( 'homero','homero123','hjs@snpp.com')
```

```
unhacker', 'hackpass','bla@bla.com'),('homero
```

A01:2025-Broken Access Control
A02:2025-Security Misconfiguration
A03:2025-Software Supply Chain Failures*
A04:2025-Cryptographic Failures
A05:2025-Injection
A06:2025-Insecure Design
A07:2025-Authentication Failures
A08:2025-Software or Data Integrity Failures
A09:2025-Security Logging & Alerting Failures*
A10:2025-Mishandling of Exceptional Conditions

Contaminación intrusiva de datos

CWE-20 Improper Input Validation
CWE-75 Failure to Sanitize Special Elements into a Different Plane (Special Element Injection)
CWE-77 Improper Neutralization of Special Elements used in a Command ('Command Injection')
CWE-79 Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')
CWE-89 Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')
CWE-98 Improper Control of Filename for Include/Require Statement in PHP Program ('PHP Remote File Inclusion')
CWE-116 Improper Encoding or Escaping of Output
...

A01:2025-Broken Access Control
A02:2025-Security Misconfiguration
A03:2025-Software Supply Chain Failures*
A04:2025-Cryptographic Failures
A05:2025-Injection
A06:2025-Insecure Design
A07:2025-Authentication Failures
A08:2025-Software or Data Integrity Failures
A09:2025-Security Logging & Alerting Failures*
A10:2025-Mishandling of Exceptional Conditions

Aspectos de diseño general inseguro

CWE-209: Generación de mensaje de error que contiene información confidencial
CWE-256: Almacenamiento desprotegido de credenciales
CWE-501: Violación de las fronteras de confianza
CWE-522: Credenciales protegidas insuficientemente

OWASP TOP10

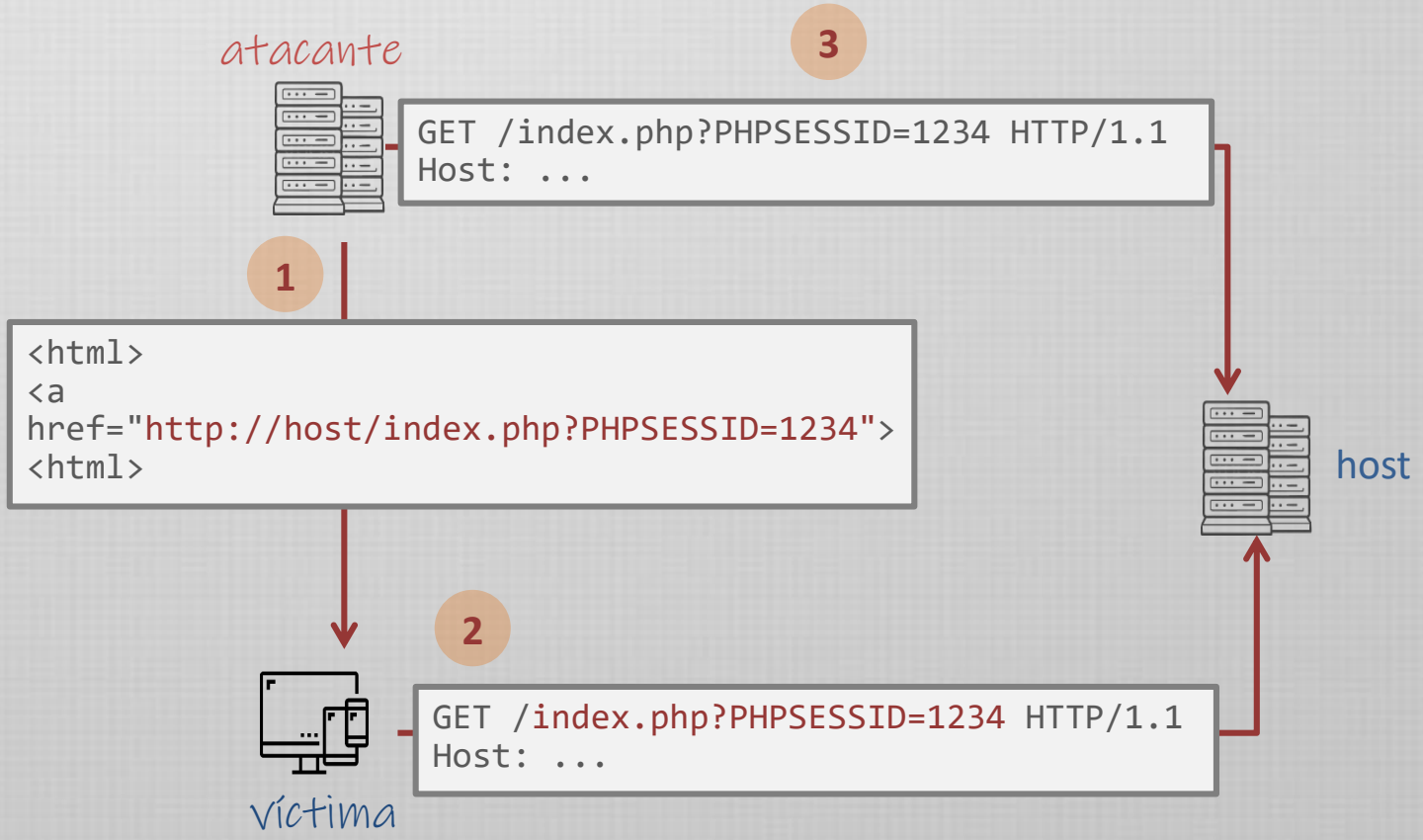
A01:2025-Broken Access Control
A02:2025-Security Misconfiguration
A03:2025-Software Supply Chain Failures*
A04:2025-Cryptographic Failures
A05:2025-Injection
A06:2025-Insecure Design
A07:2025-Authentication Failures
A08:2025-Software or Data Integrity Failures
A09:2025-Security Logging & Alerting Failures*
A10:2025-Mishandling of Exceptional Conditions

Fallas de identificación y autenticación

CWE-255 Credentials Management Errors
CWE-259 Use of Hard-coded Password
CWE-287 Improper Authentication
CWE-288 Authentication Bypass Using an Alternate Path or Channel
CWE-302 Authentication Bypass by Assumed-Immutable Data
CWE-304 Missing Critical Step in Authentication
CWE-306 Missing Authentication for Critical Function
CWE-307 Improper Restriction of Excessive Authentication Attempts
CWE-384 Session Fixation
CWE-521 Weak Password Requirements
CWE-613 Insufficient Session Expiration
...

A01:2025-Broken Access Control
A02:2025-Security Misconfiguration
A03:2025-Software Supply Chain Failures*
A04:2025-Cryptographic Failures
A05:2025-Injection
A06:2025-Insecure Design
A07:2025-Authentication Failures
A08:2025-Software or Data Integrity Failures
A09:2025-Security Logging & Alerting Failures*
A10:2025-Mishandling of Exceptional Conditions

Fallas de identificación y autenticación



OWASP TOP10

A01:2025-Broken Access Control
A02:2025-Security Misconfiguration
A03:2025-Software Supply Chain Failures*
A04:2025-Cryptographic Failures
A05:2025-Injection
A06:2025-Insecure Design
A07:2025-Authentication Failures
A08:2025-Software or Data Integrity Failures
A09:2025-Security Logging & Alerting Failures*
A10:2025-Mishandling of Exceptional Conditions

Fallas en el software y en la integridad de los datos

CWE-345 Insufficient Verification of Data Authenticity
CWE-353 Missing Support for Integrity Check
CWE-426 Untrusted Search Path
CWE-494 Download of Code Without Integrity Check
CWE-502 Deserialization of Untrusted Data
CWE-565 Reliance on Cookies without Validation and Integrity Checking
CWE-784 Reliance on Cookies without Validation and Integrity Checking in a Security Decision
CWE-829 Inclusion of Functionality from Untrusted Control Sphere
CWE-830 Inclusion of Web Functionality from an Untrusted Source
CWE-915 Improperly Controlled Modification of Dynamically-Determined Object Attributes

A01:2025-Broken Access Control
A02:2025-Security Misconfiguration
A03:2025-Software Supply Chain Failures*
A04:2025-Cryptographic Failures
A05:2025-Injection
A06:2025-Insecure Design
A07:2025-Authentication Failures
A08:2025-Software or Data Integrity Failures
A09:2025-Security Logging & Alerting Failures*
A10:2025-Mishandling of Exceptional Conditions

Fallas en registro y monitoreo

CWE-117 Improper Output Neutralization for Logs
CWE-223 Omission of Security-relevant Information
CWE-532 Insertion of Sensitive Information into Log File
CWE-778 Insufficient Logging

Hacker tests